

Web Quality & Security Audit Report

An automated, evidence-based assessment of your site's public-facing security posture, performance budget, accessibility compliance, and search-engine readiness.

owasp.org

Unauthenticated scope · public surface · 1 origin

**REPORT DATE****May 18, 2026****SCAN DURATION****63s****FINDINGS****34 issues · 5 passed****SCANNER****VibeSafe v0.4.2****CONTENTS**

Executive summary

02

Scope & methodology

03

Priority findings	04	Recommended next steps	08
All findings	05	Glossary & references	09
What passed	06	Report attestation	10
Compliance signals	07		

Prepared for
rahulsunny13@gmail.com

Report ID
rpt_cmpayn8e

Confidentiality Internal
use

01 Executive summary

owasp.org earned an overall grade of **F (356/100)**. 12 critical issues need immediate attention. 22 other findings reduce defense-in-depth.



Critical action required

This site has security gaps that put user data and trust at risk. Address the priority findings before anything else; many are single-line header changes or config tweaks. Closing the priority findings would lift this to a projected **D**.

FINDINGS BY SEVERITY

12

CRITICAL

3

HIGH

6

MEDIUM

8

LOW

5

PASSED

SCORE BY CATEGORY

 Security

356 / 100

 Accessibility

81 / 100

 SEO

92 / 100

What this report covers and what it doesn't. VibeSafe tested only what an anonymous visitor can reach: the public, unauthenticated surface of owasp.org. Authenticated routes, admin flows, and post-

login state weren't probed. Source code, dependency SBOMs, and live exploit verification are out of scope for a passive scan — see *Recommended next steps*.

02 Scope & methodology

This scan executed 21 detection modules across security, performance, accessibility, and SEO. Every finding below is backed by reproducible evidence captured at scan time.

Target URL https://owasp.org/www-project-juice-shop/

Detected stack Cloudflare Pages

Modules run 21 of 21

Authentication None — anonymous visitor only

Scan duration 63s

Scanner version VibeSafe v0.4.2

WHAT WE TESTED

- Exposed API keys & secrets
Source code leak check
Browser security defenses
HTTPS / SSL setup
Cookie & session safety
Hidden admin & config files
Cross-origin access rules
Insecure resource loading
External script safety
Email spoofing protection
Dormant subdomain check
- Leaky error messages
Exposed admin pages
Search engine exposure
Cache leak check
Cookie consent banner check
Privacy policy presence
Data-protection header signals
Accessibility compliance claim
Third-party data exposure
User rights & opt-out signals

Reproducibility. Each finding's *Evidence* block contains the raw request/response excerpt that triggered the detection. Module IDs (e.g. P1-01) map to the source files in `src/lib/scanner/modules/`.

03 Priority findings

Page 04

These 5 findings move the most points on your grade. We recommend fixing them first; the rest can be batched with normal maintenance.

CRITICAL 1. Sensitive file publicly accessible: /.env

P1-06

 Sensitive Path Exposure  /.env

The file /.env is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.env → HTTP 403
```

REMEDIATION

Block access to /.env immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

CRITICAL 2. Sensitive file publicly accessible: /.git/config

P1-06

 Sensitive Path Exposure  /.git/config

The file /.git/config is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.git/config → HTTP 403
```

REMEDIATION

Block access to /.git/config immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.git/HEAD

The file /.git/HEAD is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.git/HEAD → HTTP 403
```

REMEDIATION

Block access to /.git/HEAD immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.git/index

The file /.git/index is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.git/index → HTTP 403
```

REMEDIATION

Block access to /.git/index immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.svn/wc.db

The file /.svn/wc.db is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.svn/wc.db → HTTP 403
```

REMEDIATION

Block access to /.svn/wc.db immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

04 All findings

Page 05+

34 findings, grouped by category and ordered by severity within each.

SENSITIVE PATH EXPOSURE · 13 ISSUES

CRITICAL Sensitive file publicly accessible: /.env

P1-06

 Sensitive Path Exposure  /.env

The file /.env is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

GET /.env → HTTP 403

REMEDIATION

- Block access to /.env immediately via your hosting platform or CDN.
- Audit the file for any credentials and rotate them immediately.
- Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.
- Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.git/config

The file /.git/config is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.git/config → HTTP 403
```

REMEDIATION

Block access to /.git/config immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.git/HEAD

The file /.git/HEAD is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.git/HEAD → HTTP 403
```

REMEDIATION

Block access to /.git/HEAD immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.git/index

The file /.git/index is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.git/index → HTTP 403
```

REMEDIATION

Block access to /.git/index immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.svn/wc.db

The file /.svn/wc.db is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.svn/wc.db → HTTP 403
```

REMEDIATION

Block access to /.svn/wc.db immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.hg/store

The file /.hg/store is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.hg/store → HTTP 403
```

REMEDIATION

Block access to /.hg/store immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /index.html.bak

The file /index.html.bak is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /index.html.bak → HTTP 403
```

REMEDIATION

Block access to /index.html.bak immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /index.php.bak

The file /index.php.bak is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /index.php.bak → HTTP 403
```

REMEDIATION

Block access to /index.php.bak immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /wp-config.php.bak

The file /wp-config.php.bak is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /wp-config.php.bak → HTTP 403
```

REMEDIATION

Block access to /wp-config.php.bak immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.env.bak

The file /.env.bak is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.env.bak → HTTP 403
```

REMEDIATION

Block access to /.env.bak immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.env.old

The file /.env.old is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.env.old → HTTP 403
```

REMEDIATION

Block access to /.env.old immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.env.swp

The file /.env.swp is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.env.swp → HTTP 403
```

REMEDIATION

Block access to /.env.swp immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /web.config, /.svn/entries, /phpinfo.php, /.well-known/security.txt, /.DS_Store

Several paths that are typically hidden or admin-only returned non-404 status codes, indicating they may be accessible or discoverable.

IMPACT

Admin panels, API docs, or debug interfaces may be accessible to unauthenticated users.

EVIDENCE

```
/web.config (HTTP 403), /.svn/entries (HTTP 403), /phpinfo.php (HTTP 403), /.well-known/security.txt (HTTP 200), /.DS_Store (HTTP 403)
```

REMEDIATION

Review each flagged path and determine whether it should be publicly accessible.

Add authentication to any admin or debug interfaces.

Return 404 (not 403) for paths that should not exist — 403 confirms the path exists.

HIGH Color contrast issues detected (57 elements)

P3-01

 Accessibility  WCAG 1.4.3 - Contrast (Minimum)

Low-contrast text is difficult or impossible for many users to read. [Learn how to provide sufficient color contrast](https://dequeuniversity.com/rules/axe/4.11/color-contrast).

IMPACT

57 elements are not accessible to users with low vision, color blindness, or viewing in bright sunlight. This violates WCAG 2.2 Level AA and may result in legal complaints under ADA/Section 508.

EVIDENCE

57 elements with insufficient color contrast:

1. header > div#banner > p > a -
 2. header > div.mobile > div > a.cta-button -
 3. header > div.mobile > div > a.cta-button -
- ...and 54 more elements

REMEDIATION

Use browser DevTools or WebAIM Contrast Checker to test color combinations

Increase contrast by darkening text or lightening backgrounds (or vice versa)

For large text (18pt+), minimum ratio is 3:1 (more lenient)

For UI components (buttons, form borders), ensure 3:1 ratio against adjacent colors

SOURCEMAP EXPOSURE · 1 ISSUE

HIGH Production sourcemaps expose full source code (1 file)

P1-02

 Sourcemap Exposure  /gtag/js?id=UA-4531126-1.map

Sourcemap files (.map) map compiled JavaScript back to your original source code. When these are publicly accessible in production, anyone can read your unminified TypeScript/JSX, including business logic, component names, and file structure.

IMPACT

Attackers can read your original source to find additional vulnerabilities, understand authentication flows, and discover internal API endpoints.

EVIDENCE

HEAD /gtag/js?id=UA-4531126-1.map → HTTP 200

REMEDIATION

In Next.js, set productionBrowserSourceMaps: false in next.config.js.

Redeploy after making the change — existing .map files are still cached.

Verify by running: curl -I <your-bundle-url>.map (should return 404).

CLIENT-SIDE SECRET EXPOSURE · 2 ISSUES

 Client-Side Secret Exposure  <https://www.googletagmanager.com/gtag/js?id=UA-4531126-1>

A string with unusually high randomness (Shannon entropy > 4.5 bits/char) was found in client-side code. This pattern is common in API keys, tokens, and credentials.

IMPACT

If this is a secret or credential, it is exposed to any visitor.

EVIDENCE

```
"ChAI8PGq****2mM="
```

REMEDIATION

Review the flagged string and identify what it is.

If it is a secret or API key, move it to a server-side environment variable.

If it is expected (e.g., a product ID, nonce), you can safely ignore this finding.

 Client-Side Secret Exposure  <https://www.google-analytics.com/analytics.js>

A string with unusually high randomness (Shannon entropy > 4.5 bits/char) was found in client-side code. This pattern is common in API keys, tokens, and credentials.

IMPACT

If this is a secret or credential, it is exposed to any visitor.

EVIDENCE

```
"ABCDEFGH****89-_"
```

REMEDIATION

Review the flagged string and identify what it is.

If it is a secret or API key, move it to a server-side environment variable.

If it is expected (e.g., a product ID, nonce), you can safely ignore this finding.

 SEO  HTML <head> or <body>

Structured data (Schema.org markup) helps search engines understand your content and can enable rich snippets in search results. Rich snippets include star ratings, breadcrumbs, FAQs, and more, which increase visibility and click-through rates.

IMPACT

Page will not appear with rich snippets in search results. Missing opportunities for enhanced visibility with star ratings, prices, availability, breadcrumbs, and other rich features. Competitors with structured data may appear more prominently.

EVIDENCE

No JSON-LD structured data found

REMEDIATION

Add JSON-LD structured data to your <head> or <body>

Common types to implement:

- Organization: For company info and logo
- WebSite: For site name and search box

 SEO  Navigation links

Search engines may use `href` attributes on links to crawl websites. Ensure that the `href` attribute of anchor elements links to an appropriate destination, so more pages of the site can be discovered. [Learn how to make links crawlable](https://support.google.com/webmasters/answer/9112205)

IMPACT

Search engines cannot discover or index pages only accessible via JavaScript links. Internal link equity is not passed. Site structure is invisible to search engines.

EVIDENCE

1 link uses JavaScript instead of proper <a href> tags

REMEDIATION

Convert JavaScript links to proper tags

Add href attribute even if using onClick handlers

Use progressive enhancement (href works without JS)

For SPAs, ensure navigation URLs are in href attributes

 SEO  Page performance

Core Web Vitals (LCP, FID, CLS) are direct ranking factors for mobile search. Google uses real-world data from Chrome users to measure page experience.

IMPACT

Poor Core Web Vitals can negatively impact mobile search rankings. Users experience slow load times and layout shifts, increasing bounce rate.

EVIDENCE

Performance score: 49/100. Poor metrics: LCP: 7490ms (should be < 2500ms), FCP: 4697ms (should be < 1800ms)

REMEDIATION

Optimize Largest Contentful Paint (LCP < 2.5s)
Minimize Cumulative Layout Shift (CLS < 0.1)
Improve First Contentful Paint (FCP < 1.8s)
Use Google PageSpeed Insights for detailed analysis

 SEO  HTML <head> element

Twitter Card tags control how your page appears when shared on Twitter/X. Without a twitter:card tag, Twitter will use a basic text-only format instead of a rich media card.

IMPACT

Shares on Twitter/X will appear as plain text links without images or rich previews, reducing engagement and click-through rates.

EVIDENCE

No twitter:card meta tag found

REMEDIATION

Add <meta name="twitter:card" content="summary_large_image"> for large image cards
Or use content="summary" for smaller square images
Add <meta name="twitter:title" content="..."> (or Twitter will use og:title)
Add <meta name="twitter:description" content="..."> (or Twitter will use og:description)

LOW

sitemap.xml exists but is not referenced in robots.txt

P4-04

 SEO  /robots.txt

A valid sitemap.xml was found, but robots.txt does not advertise it via a "Sitemap:" directive. Crawlers that read robots.txt first may not discover the sitemap.

IMPACT

Slower or incomplete crawl discovery, especially for crawlers that do not probe /sitemap.xml directly.

EVIDENCE

```
robots.txt has no "Sitemap:" directive
```

REMEDIATION

Add "Sitemap: https://owasp.org/sitemap.xml" to robots.txt.

Use the absolute URL; multiple Sitemap: lines are allowed.

THIRD-PARTY SCRIPTS · 1 ISSUE

MEDIUM

1 unrecognized third-party script domain

P1-09

 Third-Party Scripts  buttons.github.io

Your site loads JavaScript from domains that are not in the list of commonly known, trusted providers. Unrecognized third-party scripts have full access to your page DOM, user keystrokes, and cookies.

IMPACT

A compromised or malicious third-party script can steal credentials, payment info, and session tokens from your users.

EVIDENCE

```
Scripts loaded from: buttons.github.io
```

REMEDIATION

Identify each domain and verify it is intentionally included.

For unrecognized scripts, investigate the source and remove if not needed.

Add Subresource Integrity (SRI) hashes to all third-party script tags.

Consider hosting critical scripts yourself instead of loading from third-party CDNs.

ACCESSIBILITY COMPLIANCE · 1 ISSUE

 Accessibility Compliance  <https://owasp.org/www-project-juice-shop/>

This signal is derived from Lighthouse's automated accessibility checks, which cover a subset of WCAG 2.2 success criteria detectable by static analysis. It is NOT a full WCAG 2.2 AA audit and cannot be used as a compliance attestation. Relevant regulatory frameworks that reference WCAG 2.2 AA include the ADA (US), Section 508 (US federal), and EN 301 549 (EU) — conformance with these requires a comprehensive audit by a qualified assessor, not an automated scan.

IMPACT

A lower Lighthouse accessibility score suggests more potential barriers for users of assistive technology. It does not constitute a legal finding. Organisations subject to ADA, Section 508, or EN 301 549 should commission a qualified WCAG 2.2 AA audit independently of this scan.

EVIDENCE

Lighthouse accessibility subset score tier: moderate (70–89). Source: lab. No accessibility statement link was detected on this page.

REMEDIATION

Review the detailed Lighthouse accessibility report for specific rule failures.

Use a screen reader (NVDA, VoiceOver, JAWS) to manually test key user flows.

Engage an accessibility specialist for a WCAG 2.2 AA conformance evaluation.

Consider publishing an accessibility statement describing known limitations and remediation plans.

AI DISCOVERABILITY · 1 ISSUE

 AI Discoverability  /llms.txt

llms.txt (llmstxt.org) is an emerging convention that gives AI assistants a curated, plain-Markdown map of your most important content. Without it, AI search tools fall back to guessing from your full HTML, which is noisier and may surface the wrong pages.

IMPACT

Reduced control over how AI assistants summarise and cite your site. This is an opportunity gap, not a defect — many sites do not yet ship llms.txt.

EVIDENCE

GET <https://owasp.org/llms.txt> did not return a usable file

REMEDIATION

Add an /llms.txt file at the site root.

First line must be an H1 with the site/product name: "# Acme Docs".

Optionally add a blockquote summary, then "###" sections listing key pages as "[Title](https://...): short note".

Keep it curated — link the canonical, high-value pages only.

LOW Account-deletion affordance not observed in DOM

P5-06

 Privacy & Compliance  <https://owasp.org/www-project-juice-shop/>

No "delete account" or "close account" control was detected in the page DOM. GDPR Arts. 17-18 grant users rights to erasure and restriction of processing; many privacy frameworks expect an accessible self-service path. This is a DOM observation — the control may be behind authentication or on a settings page not reached by the crawler.

IMPACT

Users may lack a convenient self-service path to exercise their privacy rights. Absent affordances can increase support burden and regulatory exposure.

EVIDENCE

Auth/account surface was detected (password input or auth link present). No matching control found in 314 scanned link/button text(s).

REMEDIATION

Add a clearly-labelled "Delete my account" button or link in the user settings or profile page.
Ensure the control is reachable without contacting support.
Link to the control from the privacy policy.

LOW Data-export/download affordance not observed in DOM

P5-06

 Privacy & Compliance  <https://owasp.org/www-project-juice-shop/>

No "download my data" or "export data" control was detected in the page DOM. GDPR Art. 20 (data portability) and CCPA §1798.100 give users rights to receive a copy of their personal data. This is a DOM observation — the control may be behind authentication or on a settings page not reached by the crawler.

IMPACT

Users may lack a convenient self-service path to exercise their privacy rights. Absent affordances can increase support burden and regulatory exposure.

EVIDENCE

Auth/account surface was detected (password input or auth link present). No matching control found in 314 scanned link/button text(s).

REMEDIATION

Add a "Download my data" button on the user account or settings page.
Generate a JSON or CSV export of the user's personal data when requested.
Document the export format and what data is included.

LOW

"Do Not Sell / Share My Personal Information" affordance not observed in DOM

P5-06

 Privacy & Compliance  <https://owasp.org/www-project-juice-shop/>

No "Do Not Sell My Personal Information", "Your Privacy Choices", or "Do Not Share My Personal Information" link or button was detected. CCPA §1798.120 requires businesses that sell personal data to California residents to provide a prominent opt-out link. This is a DOM observation — if the site does not sell personal data, this affordance may not be required.

IMPACT

Users may lack a convenient self-service path to exercise their privacy rights. Absent affordances can increase support burden and regulatory exposure.

EVIDENCE

Auth/account surface was detected (password input or auth link present). No matching control found in 314 scanned link/button text(s).

REMEDIATION

If you sell or share personal data, add a "Do Not Sell or Share My Personal Information" link to the site footer.

Link to an opt-out mechanism or privacy preference centre.

Consult legal counsel to confirm whether CCPA obligations apply to your site.

INFO

Privacy policy link observed

P5-02

 Privacy & Compliance  <https://demo.owasp-juice.shop/>

A link matching common privacy policy text or URL patterns was found in the page HTML (page body). This is an observation only — the content or adequacy of the linked policy has not been evaluated.

IMPACT

None from this finding. Policy content quality is not assessed here.

EVIDENCE

Link text: "Privacy Policy" | href: "https://demo.owasp-juice.shop/" | Placement: page body

 Privacy & Compliance

 www.googletagmanager.com, www.google-analytics.com, buttons.github.io, raw.githubusercontent.com, img.shields.io, www.bestpractices.dev, d322cqt584bo4o.cloudfront.net, github-readme-stats.vercel.app, w.soundcloud.com, dwt.soundcloud.com, widget.sndcdn.com, api.github.com, , api-widget.soundcloud.com, wave.sndcdn.com

The page loads resources from or sets cookies on third-party domains. A privacy policy link was found on the page, which is a positive signal. This finding is informational — it lists the processors for awareness. GDPR and CCPA require that your privacy policy accurately describes each processor and the data it receives.

IMPACT

Low — a privacy policy link is present. Ensure the policy accurately describes each listed processor and the data they receive.

EVIDENCE

Third-party processors detected: Google Tag Manager (www.googletagmanager.com), Google Analytics (www.google-analytics.com), buttons.github.io, raw.githubusercontent.com, img.shields.io, www.bestpractices.dev, d322cqt584bo4o.cloudfront.net, github-readme-stats.vercel.app, w.soundcloud.com, dwt.soundcloud.com, widget.sndcdn.com, api.github.com, , api-widget.soundcloud.com, wave.sndcdn.com.

A privacy-policy link was observed on the page.

REMEDIATION

Confirm that your privacy policy names each third-party processor listed above.
Verify that your cookie consent mechanism (if required) covers these processors.
Periodically audit third-party integrations and remove unused ones.

 Security Headers  Initial HTML `<script src>` tags

Subresource Integrity (SRI) lets the browser verify a fetched script matches a known hash before executing it. Cross-origin scripts loaded without an `integrity` attribute will be executed unconditionally, so a compromise of the CDN, a typosquatted host, or a hostile mirror can silently swap the script for malicious code.

IMPACT

If any of the third-party CDNs serving these scripts is compromised, the swapped script runs with full access to your origin — including session cookies, localStorage, and user input.

EVIDENCE

```
<script src="https://www.google-analytics.com/analytics.js"> (no integrity)
<script src="https://buttons.github.io/buttons.js"> (no integrity)
```

REMEDIATION

For each cross-origin `<script src="...">`, add `integrity="sha384-..."` and `crossorigin="anonymous"`.
Generate hashes via: `openssl dgst -sha384 -binary <file> | openssl base64 -A`
Prefer pinning a specific version of the asset so the hash stays stable.

 Security Headers  HTTP response headers

COOP isolates your page from cross-origin windows opened via `window.open` or popups. Without it, a malicious site you opened a popup to can read state from your window via opener references, enabling cross-window data leaks (Spectre-class and tabnapping risks).

IMPACT

Cross-origin popups or openers can probe your page state. Cross-origin isolation features (SharedArrayBuffer, high-resolution timers) also require this header.

EVIDENCE

```
cross-origin-opener-policy header not present
```

REMEDIATION

Add: Cross-Origin-Opener-Policy: same-origin
Use same-origin-allow-popups if you need to keep references to popups you open.

 Security Headers  HTTP response headers

COEP requires every cross-origin resource you load to opt-in via CORP or CORS. Combined with COOP it enables cross-origin isolation, which is required by SharedArrayBuffer and high-resolution timers and which materially raises the bar for cross-process side-channel attacks.

IMPACT

Without COEP, cross-origin isolation is off and side-channel attacks across origins are easier to mount. Some advanced APIs (SharedArrayBuffer, performance.measureUserAgentSpecificMemory) are also unavailable.

EVIDENCE

```
cross-origin-embedder-policy header not present
```

REMEDIATION

Add: Cross-Origin-Embedder-Policy: require-corp

If third-party embeds break, try credentialless instead of require-corp.

EXPOSED DEVELOPMENT INTERFACE · 1 ISSUE

 Exposed Development Interface  /.well-known/security.txt

security.txt present is accessible to unauthenticated users. Development and debugging interfaces expose internal system details and should be restricted or removed in production.

IMPACT

Attackers can map your API surface, discover internal endpoints, and use debug features to gather information for further attacks.

EVIDENCE

```
GET /.well-known/security.txt → HTTP 200
```

REMEDIATION

Remove or disable security.txt present in production.

If required, restrict access to internal network or authenticated admin users only.

Add authentication middleware to /.well-known/security.txt.

05 What passed

Page 06

11 checks passed cleanly. Worth keeping a record so future regressions are easy to spot.

✓ **HTTPS / SSL setup**

TLS Configuration — no issues detected.

✓ **Cookie & session safety**

Cookie & Storage — no issues detected.

✓ **Cross-origin access rules**

CORS Configuration — no issues detected.

✓ **Insecure resource loading**

Mixed Content — no issues detected.

✓ **Email spoofing protection**

DNS & Email Security — no issues detected.

✓ **Dormant subdomain check**

Subdomain Takeover — no issues detected.

✓ **Leaky error messages**

Error Disclosure — no issues detected.

✓ **Search engine exposure**

robots.txt & Sitemap — no issues detected.

✓ **Cache leak check**

Cache Configuration — no issues detected.

✓ **Cookie consent banner check**

Cookie Consent — no issues detected.

✓ **Data-protection header signals**

Data Protection Headers — no issues detected.

06 Compliance signals

Page 07

⚠ Not legal advice. Not a compliance attestation. Signal detection only.

GDPR

⚠ Not legal advice. Not a compliance attestation. Signal detection only.

Not observed — Account-deletion affordance not observed in DOM

Not observed — Data-export/download affordance not observed in DOM

Not observed — "Do Not Sell / Share My Personal Information" affordance not observed in DOM

Observed — Privacy policy link observed

Observed — Third-party data processors observed (privacy policy link present)

CCPA

⚠ Not legal advice. Not a compliance attestation. Signal detection only.

Not observed — Account-deletion affordance not observed in DOM

Not observed — Data-export/download affordance not observed in DOM

Not observed — "Do Not Sell / Share My Personal Information" affordance not observed in DOM

Observed — Privacy policy link observed

Observed — Third-party data processors observed (privacy policy link present)

WCAG / ACCESSIBILITY

⚠ Not legal advice. Not a compliance attestation. Signal detection only.

Not observed — Lighthouse accessibility signal: moderate (70–89) score tier

07 Recommended next steps

Page 08

A pragmatic three-week plan. Each step is reversible and ships behind a feature flag where appropriate.

THIS WEEK

Patch the easy wins

Address the low-effort header and configuration fixes called out in the priority section. Typically a single deploy, **+5 to +10 points** on the security score.

NEXT SPRINT

Roll out defense-in-depth

Ship a report-only Content Security Policy, raise HSTS to a preload-ready max-age, and enable Subresource Integrity for third-party scripts.

WITHIN 30 DAYS

Run an active DAST scan

Passive scans can't verify exploitability. Verify your domain and run an active test to probe SQL injection, XSS, and API fuzzing on authenticated routes.

Want to compare this scan to your last one? Re-scan from your dashboard and select *Compare to previous*. VibeSafe will show which findings opened, closed, or changed severity since this report.

OUT OF SCOPE FOR A PASSIVE SCAN

Authenticated flows. Broken access control, IDOR, privileged endpoints — need a logged-in session to test.

Source-code findings. Hardcoded secrets in private repos, vulnerable dependency versions, SSRF gadgets — require code access.

Live exploit probes. Real SQL injection, XSS payloads, API fuzzing — require domain verification and explicit consent.

08 Glossary & references

Page 09

CSP	Content Security Policy — an HTTP header that tells the browser which sources of scripts, styles, images, and connections are allowed. Mitigates XSS impact.
HSTS	HTTP Strict Transport Security — instructs browsers to refuse plaintext HTTP to your origin for a given duration. Preloading bakes this into the browser itself.
SRI	Subresource Integrity — a cryptographic hash on a <script> or <link> tag. The browser refuses to execute the resource if the bytes don't match.
SameSite	A cookie attribute (Strict, Lax, None) controlling whether the cookie is sent on cross-site requests. Mitigates CSRF.
LCP / INP / CLS	Core Web Vitals — Largest Contentful Paint (when the main content appears), Interaction to Next Paint (responsiveness), Cumulative Layout Shift (visual stability).
WCAG 2.2 AA	Web Content Accessibility Guidelines, level AA — the legal baseline for accessibility in the EU, UK, and most US public-sector procurement.
DAST	Dynamic Application Security Testing — probing a running application with real attack payloads, as opposed to static analysis of source code.
KEV / EPSS	CISA's Known Exploited Vulnerabilities catalog and FIRST's Exploit Prediction Scoring System — used to rank CVEs by real-world exploitation rather than CVSS alone.

REFERENCES

OWASP Secure Headers Project — owasp.org/www-project-secure-headers
Mozilla Observatory — observatory.mozilla.org
Google web.dev — web.dev/vitals
W3C WCAG 2.2 — w3.org/TR/WCAG22

09 Report attestation

This report was generated automatically by VibeSafe and is not a substitute for a manual penetration test. It is designed for triage, prioritization, and conversation — not certification.

Report ID	rpt_cmpayn8e
Scan ID	cmpayn8eu0027r9k8sghzrf5a
Issued	May 18, 2026
Valid until	August 16, 2026 (or next deploy)
Scanner version	VibeSafe v0.4.2
Prepared for	rahulsunny13@gmail.com

ISSUED BY	REVIEWED BY
VibeSafe Automated Scanner vibesafe.app · contact@vibesafe.app	Name & date (optional human review)

How to read this report. Severity reflects exploitability and blast radius, not absolute risk. A high-severity finding on a low-traffic marketing page is less urgent than a medium on the login flow. Use the *Priority findings* section as your starting point — it's already ordered for you.

© 2026 VibeSafe. This report is confidential and intended for the named recipient only. Findings are based on the public response of owasp.org at the time of scanning and may not reflect the current state of the site.